💣 Fase 3: Analisis de Vulnerabilidades: Analisis

📖 Introducción a la Fase

Esta etapa consiste en evaluar los activos descubiertos para detectar fallos de seguridad o configuraciones erróneas explotables. En este escenario, contrastamos la información recolectada contra vectores de ataque como **Subdomain Takeover** y **Dangling DNS**, determinando el riesgo real sobre la infraestructura de **mercadolibre.com**.

🔍 Busqueda Automatizada de Vulnerabilidades (Nuclei)

Una vez finalizadas las fases de reconocimiento y fingerprinting, se inició la etapa de **análisis de vulnerabilidades** utilizando la herramienta **Nuclei**, la cual permite detectar posibles configuraciones inseguras o vulnerabilidades conocidas mediante el uso de plantillas automatizadas.

🛠️ Herramienta utilizada

```
nuclei
```

Nuclei es un escáner de vulnerabilidades basado en plantillas desarrollado por ProjectDiscovery. La herramienta permite ejecutar múltiples pruebas automatizadas para detectar configuraciones inseguras, exposiciones de información y vulnerabilidades conocidas en aplicaciones web.

⚙️ Instalación de la herramienta

La herramienta se instaló utilizando el gestor de paquetes de Go mediante el siguiente comando:

```
┌──(kali㉿kali)-[~]
└─$ go install -v github.com/projectdiscovery/nuclei/v3/cmd/nuclei@latest
go: downloading github.com/projectdiscovery/nuclei/v3 v3.7.1
go: downloading github.com/projectdiscovery/nuclei v1.1.7
go: downloading github.com/projectdiscovery/gologger v1.1.68
```

```
go install -v github.com/projectdiscovery/nuclei/v3/cmd/nuclei@latest
```

💻 Ejecución del análisis

Una vez instalada la herramienta, se ejecutó un análisis sobre el dominio principal del objetivo utilizando el siguiente comando:

```
┌──(kali㉿kali)-[~]
└─$ nuclei -u mercadolibre.com -silent
[azure-domain-tenant] [http] [info] https://login.microsoftonline.com:443/mercadolibre.com/v2.0/.well-known/openid-configurati
on ["882c0c7c-23db-40e6-9992-5b2c0f064e05"]
[waf-detect:cloudfront] [http] [info] https://mercadolibre.com
[tls-version] [ssl] [info] mercadolibre.com:443 ["tls12"]
[tls-version] [ssl] [info] mercadolibre.com:443 ["tls13"]
[missing-sri] [http] [info] https://mercadolibre.com/ ["https://http2.mlstatic.com/ui/navigation/2.3.5/mercadolibre/navigation
.css"]
[http-missing-security-headers:strict-transport-security] [http] [info] https://mercadolibre.com
[http-missing-security-headers:permissions-policy] [http] [info] https://mercadolibre.com
[http-missing-security-headers:x-frame-options] [http] [info] https://mercadolibre.com
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] https://mercadolibre.com
[http-missing-security-headers:referrer-policy] [http] [info] https://mercadolibre.com
[http-missing-security-headers:clear-site-data] [http] [info] https://mercadolibre.com
[http-missing-security-headers:content-security-policy] [http] [info] https://mercadolibre.com
[http-missing-security-headers:x-content-type-options] [http] [info] https://mercadolibre.com
```

```
nuclei -u mercadolibre.com -silent
```

Este comando ejecuta múltiples plantillas de detección sobre el dominio analizado y muestra únicamente los resultados relevantes.

📊 Resultados obtenidos

El análisis automatizado no detectó **vulnerabilidades críticas**, pero sí permitió identificar diversas **características de configuración e infraestructura** del sitio.

Entre los resultados más relevantes se observó:

- Uso de **Amazon CloudFront** como infraestructura de distribución y protección.
- Soporte para **TLS 1.2 y TLS 1.3**, lo cual indica el uso de protocolos modernos de seguridad.
- Certificado SSL emitido por **Amazon**, con soporte para dominio wildcard (`*.mercadolibre.com`).
- Identificación del uso de **React** como tecnología de frontend.
- Presencia de registros de seguridad de correo como **DKIM y DMARC**, configurados para proteger el dominio frente a suplantación de identidad.
- Infraestructura de correo basada en **Google Workspace / Google Apps**.
- Servidores DNS administrados mediante **AWS Route53**.

Adicionalmente, Nuclei reportó la ausencia de algunos **headers de seguridad HTTP** como:

- `Content-Security-Policy`
- `X-Frame-Options`
- `Referrer-Policy`
- `Permissions-Policy`

Sin embargo, este tipo de hallazgos son clasificados como **informativos**, ya que no implican necesariamente una vulnerabilidad explotable.

🧠 Interpretación del resultado

Los resultados indican que el dominio analizado se encuentra desplegado sobre una infraestructura moderna basada en **AWS y servicios de CDN**, con configuraciones de seguridad estándar para una plataforma web de gran escala.

La mayoría de los hallazgos corresponden a **información de configuración y tecnologías utilizadas**, lo cual resulta útil para comprender mejor la arquitectura del sistema.

📃 Conclusión

El análisis con **Nuclei** permitió realizar una revisión automatizada inicial del dominio en busca de vulnerabilidades conocidas. En este caso no se identificaron vulnerabilidades críticas, pero sí se obtuvieron datos relevantes sobre la infraestructura, tecnologías y configuraciones de seguridad utilizadas por el sitio.